Link to 2026 ACAMP Wiki

Advance CAMP Thu. Oct 29 2026 10:20am - 11:10

Room - 4

Session Title: Scaling Shibboleth 4 SP Deployments

CONVENER: Scott Cantor - Shib Project

MAIN SCRIBE(S): Phil Smart

ADDITIONAL CONTRIBUTORS: Chris B.?

of ATTENDEES: 27

DISCUSSION:

- Scott describing the new architecture of the Shibboleth SP
    - Envision multiple shared hubs vs 1 shared for the whole campus
    - Hub Design goals
        - Running an agent, you care about local policy, but you do not care about secrets and protocols (SAML etc.).
        - To cater for this, the new design fits a different architecture, based around a shared hub or a set of hubs.
    - Describing the benefits of a shared hub and the campus divisions, for example, Central IT might run a hub, but other administrative areas might want to run their own Hub.
        - Need to manage a secure connection between Agents and the shared Hub
        - (This is similar to the security model of OpenID Connect, using a shared secret.)
        - But issuing client credentials for agents as this scales up needs thought. You've now got Agent credentials alongside any protocol-required credentials.

            - So, Agents could authenticate using LDAP etc. (Enterprise enabled). So, you can use service accounts to manage your Agents. (Not all organisations have a good process for service accounts).
        - ***So, would like to talk through this process. How do you issue credentials to all these agents?***
        - ***And how should the Agent configuration in the hub look?***
            - Currently requires small amount of XML, but we'd like to make that more efficient, so describing agents would be easier, maybe a flat file of AgentIDs and optionally credentials if no service account lookup.
            - Maybe a database option would also make sense. Where a basic UI could be used to administer it.
- Mike:
    - Can anybody imagine this as a hosted 'in the cloud' type service
- Scott:
    - Yes, sure.
    - You can outsource the running of the hub.
    - But you can not federate the Hub across organisations.
        - But we might not have that on day one.
- (name) Agent identities are a necessity of the hub operation. You do not want to run a single Agent, as that would be the same as a single RP.
    - A cluster of agents for a single application might have the same identity
    - But generally you want individual identities of agents
- (name): Did you look at the SAML model for agent to hub registration? (using keys etc.)
    - Scott: no, did not want that approach. Overly complicated
    - Scott: mTLS is hard to implement/use. Might be a later feature
    - Scott: username and password is the simplest approach
- Keith: Think of service management
    - Agents are principals and long-term identities.
    - So if you've good human identity management processes, apply those to the agent identity case.
- Scott:
    - If you want a massive vhost environment, the SP had a way to make that automatic.
    - Assigning EntityID pased on the vhost
    - There is a way to do that in the Hub: base entityID on the vhost it sees.

- Chris B.:
    - Not sure we would want to use our existing processes for these kind of accounts, e.g. credential rotation.
- Scott:
    - Decoupled agentID from credentials used to authenticate (username and password). This helps with the credential rotation processes.
    - Often tied to what your organisation processes exist, and what you are allowed to do wrt to service accounts.
- Chris B.
    - Would do this with HttpBasic auth…htpaswd files
- Scott:
    - Yes, can support those kinds of credentials
- Matthew:
    - Db backed might be ideal, what are the timescales?
- Scott:
    - Hopefully the idea gets into the first release.
    - But need to keep it abstract enough to support multiple options
        - So db might come later. Perhaps flat files first.
    - Something neater than XML.
    - Noting, if you want to do more advanced configuration, you'll eventually get back to XML. JSON and simple property type files are not suitable for advanced configuration
        - But most agents will work off simple defaults and not require the advanced options
    - GUIs and things to help with this later down the road
- Chris B
    - Departmental admin: my own Hub would be an Ansible playbook for my own SPs/Agents
- Scott:
    - Straightforward when you control both ends. Lots of organisational options around Docker and Ansible etc.
- (name):
    - Challenged with maintaining and rotating service account credentials.
- Scott:
    - A long secret is a PSK.
- (name):

    - Organisations have policies around the rotation of passwords.
    - Windows has the concept of a Managed Service Account (MSA or gMSA) where the server interacts with Active Directory domain controllers to automatically manage the password every 30 days. It would great for the SP to support this but it understandably transfers the burden to the project team.
- Scott:
    - A public-private key, being different from a PSK, had a longer term plan for some kind of token based enrollment process.
        - Using the token to enrol the agents, similar to OpenID RP dynamic registration.
        - Which is possibly a longer term feature to add.
            - Would need a database for that
- (name & Scott)
    - Commercial certs are shrinking to have short expiry.
    - Scott: But you would not want to use the same process as commercial TLS for this. Use self-signed certificates for TLS between the hub and SPs.
    - We did implement PKIX validation if you wanted root CA-signed certificate in addition to self-signed etc.
- Scott:
    - The goals here, though, were not to have to deal with keys. Did not want to require TLS type trust.
    - So simplified this to the PSK (password) case.
    - Some kind of token to provision agents would work.
- Keith:
    - So was this a goal for database use?
- Scott:
    - Yes, but perhaps not on day one.
    - Flat file is simple and we can hopefully get that for V1.
    - So service account management still seems to be hard in organisations, is what I'm hearing?
- Chris B.
    - Has some (PS. 'governance') or ownership-type issues around that.
- Scott:
    - Take the same approach as for human identities. It should be easy to do on the technical level.
- Chris B.

    - As an operator, I do not own that IdP. So needs other people to be involved/own this process.
- Scott:
    - Scaling problems we wanted to explore
    - We need your thoughts and feedback on how you would deploy this
- Chris B.
    - Need to point somebody to the page that shows them how to do that.
- Maybe there will be a hub of last resort, depending on the organisation and who ends up doing what.
- Scott:
    - Hub might be able to generate some basic boilerplate to help with configuration
    - Agent cares about URLs, paths, rules, but the hub does not. Hub will need to serve up OpenID metadata and so it will need that capability to serve up other files etc (e.g. SAML)
- Matthew
    - Need to give guidance to single SP deployments. Is V4 a good fit for their deployment model?
- Scott:
    - Could be a good fit when needing multiple protocol support (over proxy somewhere else)
    - We want to make it easier in those situations to deploy both halves (eventually). But that is not a day one story.
        - But taking a Hub that is easy to deploy e.g. via Docker, might be an option if we've capacity.
        - Will look into this for the next stage
        - OOB is all localhost, HTTP, easy deployment. Building on that would be to wrap the Java part. (Not years down the road, but possibly next year.)
    - As soon as SPv4 comes out the clock is ticking on SPv3.